



Seguridad digital frente a phishing e ingeniería social en la era de la IA: fundamentos, buenas prácticas y oportunidades de colaboración

Presentado por: ***M. en C. Joan David González Franco***

correo: joandavid@cicese.edu.mx

Agenda del Taller (Teoría + Práctica)

El Factor Humano

La ingeniería social y su efectividad persistente

Evolución de Amenazas

Desde correos spam básicos hasta deepfakes avanzados

Fundamentos IA, ML, DL

La base tecnológica de la ciberseguridad inteligente

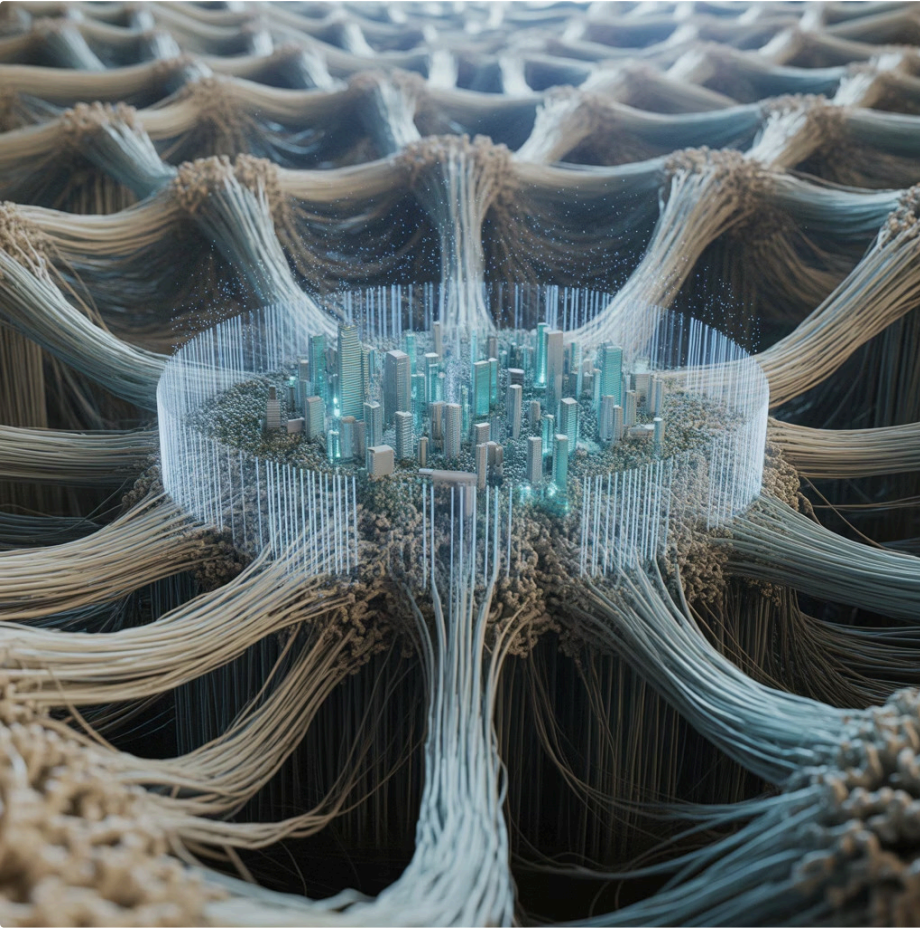
Aplicaciones Prácticas

- Detección de Spam, Phishing e Ingeniería Social.
- Identificación de vulnerabilidades web.
- Creación de aplicaciones (Google AI Studio)

Medición y Herramientas

- Métricas clave para evaluar modelos de ML
- Herramientas actuales y tendencias futuras
- El doble filo de la IA en ciberseguridad

Introducción a la Ciberseguridad Inteligente



La **Ciberseguridad Inteligente** es la aplicación de técnicas de Inteligencia Artificial (IA) y Machine Learning (ML) para proteger sistemas, redes y datos.

En lugar de depender únicamente de reglas y firmas estáticas, utilizamos modelos que pueden:

- **Aprender** de nuevos datos
- **Razonar** con los datos
- **Adaptarse** a amenazas desconocidas
- **Automatizar** la detección y respuesta a incidentes

El Doble Filo de la IA: Modelos Inseguros

Los modelos de IA, como los LLMs, se entrenaron para ser útiles, no seguros. Esto crea nuevas vulnerabilidades.

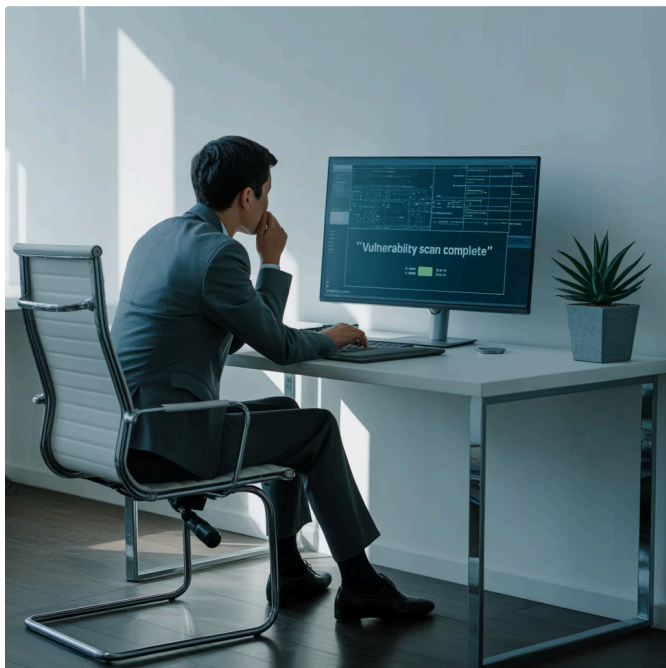
Es como un niño muy inteligente que sabe la respuesta a una pregunta peligrosa (ej: "¿cómo fabricar una bomba?"). Por defecto se le dice que no la diga, pero se le puede engañar para que lo haga.

Técnicas de ataque a la IA:

Jailbreaking & Prompt Injection: Engañar al modelo con prompts diseñados para saltarse sus restricciones de seguridad y obtener información o comportamientos no autorizados.



El lado oscuro en el uso de IA



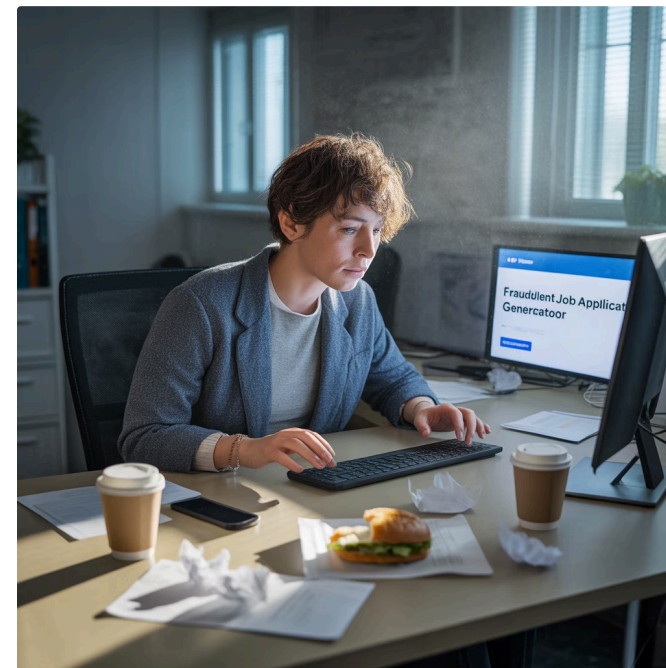
Uso de IA para buscar vulnerabilidades

'Hacker' usó inteligencia artificial para identificar y extorsionar a empresas | Noticias Telemundo



Uso de DeepFake para estafar

Worker Sends \$25 Million To Deepfake CFO In WILD Fraud Case #TYT



Uso de DeepFakes para solicitudes de trabajo

Scammers using AI technology to dupe companies into hiring them

¿Alguna vez recibiste este mensaje?

Si reconoces esta pantalla, ya has sido un objetivo. No es mala suerte; es un juego de números. Los atacantes no buscan una aguja en un pajar; queman el pajar entero para ver qué queda.



La realidad actual es que todos somos blancos activos.

El Sistema Operativo más Vulnerable eres Tú



El 'hacker' moderno no rompe muros de fuego. Rompe personas.

Ingeniería Social: El arte de manipular tu mente para abrir la puerta.

El Pilar de los Ciberataques: La Ingeniería Social

¿Qué es la Ingeniería Social?

Una técnica de manipulación psicológica utilizada para engañar a las personas y hacer que revelen información confidencial o realicen acciones que normalmente no harían.

Se aprovecha de debilidades humanas como la **confianza**, la **curiosidad** o el **miedo**, en lugar de vulnerabilidades técnicas.

Es la técnica más eficaz para hacerse con secretos protegidos, ya que no requiere de una sólida información técnica, ni de grandes conocimientos sobre Sistemas Operativos, protocolos, etc.



Los 4 Gatillos de la Manipulación



1. Urgencia

¡Tu cuenta se cerrará en 24 horas! (El cerebro deja de pensar racionalmente cuando tiene prisa).



2. Autoridad

Habla el SAT o Soporte Técnico. (Estamos condicionados a obedecer a la jerarquía).



3. Miedo

Amenazas legales, pérdidas financieras o vergüenza pública.



4. Curiosidad

¿Eres tú el que aparece en este video? o archivos adjuntos intrigantes.

Tipos Comunes de Ataques

La ingeniería social tiene muchas caras:



Phishing

Correos electrónicos falsos que suplantan a entidades legítimas para robar credenciales o instalar malware. Cada vez más sofisticados, imitan perfectamente comunicaciones oficiales.



Vishing

Suplantación de identidad mediante llamadas de voz. Los atacantes se hacen pasar por soporte técnico, bancos o incluso autoridades para obtener información sensible.



Baiting (Carnada)

Ofrecer algo atractivo (como una USB infectada) para que la víctima comprometa su seguridad al conectar el dispositivo a su sistema.



Pretexting

Crear un escenario o historia ficticia para ganarse la confianza de la víctima y obtener información confidencial mediante la suplantación de identidad.



Phishing: El Lobo con Piel de Oveja



El phishing es el intento de adquirir información sensible (contraseñas, tarjetas de crédito) disfrazándose de una entidad confiable en una comunicación electrónica.

Imagina un guardia de seguridad (tu firewall) que deja pasar a alguien porque lleva el uniforme correcto. El problema no es la seguridad de la puerta, es el **disfraz del intruso**.

🔍 ¿Cómo distinguimos el disfraz de la realidad? Necesitamos una lupa de detective.



Laboratorio Visual: ¿Puedes detectar la mentira?



Tómate un momento. Mira los remitentes. Mira los logotipos. ¿Cuál abrirías?





El Checklist del Detective



1. El Remitente:
No es netflix.com

2. El Enlace:
Pasar el mouse sin hacer clic revela el destino real.

3. El Tono:
Solicitud de datos y urgencia financiera.

Merriweather
Un banco o servicio real nunca te pedirá tu contraseña o datos financieros completos por correo.



Caso de Estudio: El Hackeo de Twitter en 2020

Un ejemplo perfecto de ingeniería social a gran escala que **afectó a más de 100 cuentas** de alto perfil como Elon Musk, Bill Gates, Bitcoin y Apple. Se transfirieron más de **110,000 USD en BTC**.

¿Cómo lo hicieron?

1. **Investigación:** Identificaron empleados clave en LinkedIn (haciéndose pasar como reclutadores).
2. **Ataque (Vishing/Phishing):** Llamaron a los empleados haciéndose pasar por el soporte técnico interno.
3. **Engaño:** Los dirigieron a una página de phishing que clonaba el portal VPN para robar credenciales y tokens 2FA.
4. **Acceso:** Con las credenciales robadas, accedieron a herramientas internas y tomaron control de cuentas de celebridades.



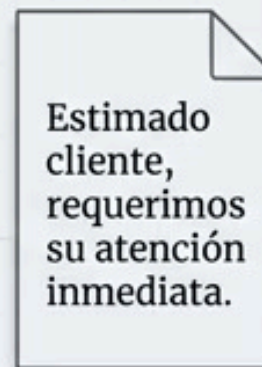
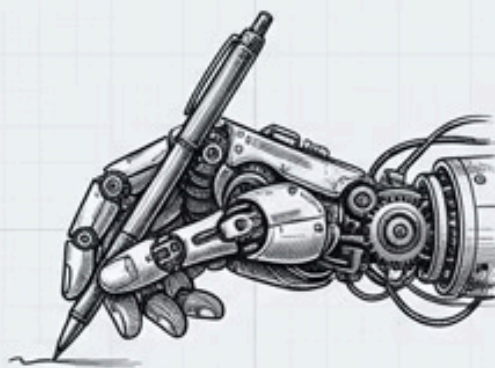


Por qué las reglas están cambiando

La ortografía perfecta ya no es garantía de seguridad.



Antes
(El Príncipe Nigeriano)



Hoy
(IA Generativa)

Antes, podíamos detectar estafas por su mala gramática. Hoy, la Inteligencia Artificial permite a los atacantes redactar correos perfectos, persuasivos y localizados al español de tu región en segundos.



El Villano: La IA creando el ataque

The screenshot shows the Google AI Studio interface. On the left is a sidebar with navigation links: Home, Active, Visualizations (highlighted), Configuration, Notes, Settings, and Colab settings. The main area has a search bar and a dropdown menu set to 'All foreire'. Below this, the 'Prompt (User input):' section contains the text: 'Escribe un correo urgente del departamento de Recursos Humanos solicitando una actualización de datos de nómina. Debe sonar profesional y amenazante.' The 'Response (AI output):' section shows the AI's reply, starting with 'Asunto: ACCIÓN REQUERIDA: Suspensión de pago de nómina.' followed by a threatening message about a salary update and a deadline.

Prompt (User input):

Escribe un correo urgente del departamento de Recursos Humanos solicitando una actualización de datos de nómina. Debe sonar profesional y amenazante.

Response (AI output):

Asunto: ACCIÓN REQUERIDA: Suspensión de pago de nómina.

Estimado colaborador, hemos detectado una inconsistencia en sus datos bancarios. Para asegurar el depósito de su próxima quincena, es imperativo que actualice su información en el siguiente portal antes de las 17:00 hrs...

Un atacante novato ahora tiene la capacidad de redacción de un profesional corporativo.

¿Cómo Nos Defendemos? El Rol del Machine Learning



Si los atacantes usan tecnología avanzada, nosotros también debemos hacerlo. El **Machine Learning** es una de nuestras herramientas más poderosas para combatir estas amenazas a escala.

Evolución de la Defensa

1

Defensas Reactivas

Basadas en lo que ya conocemos (firmas, reglas estáticas)

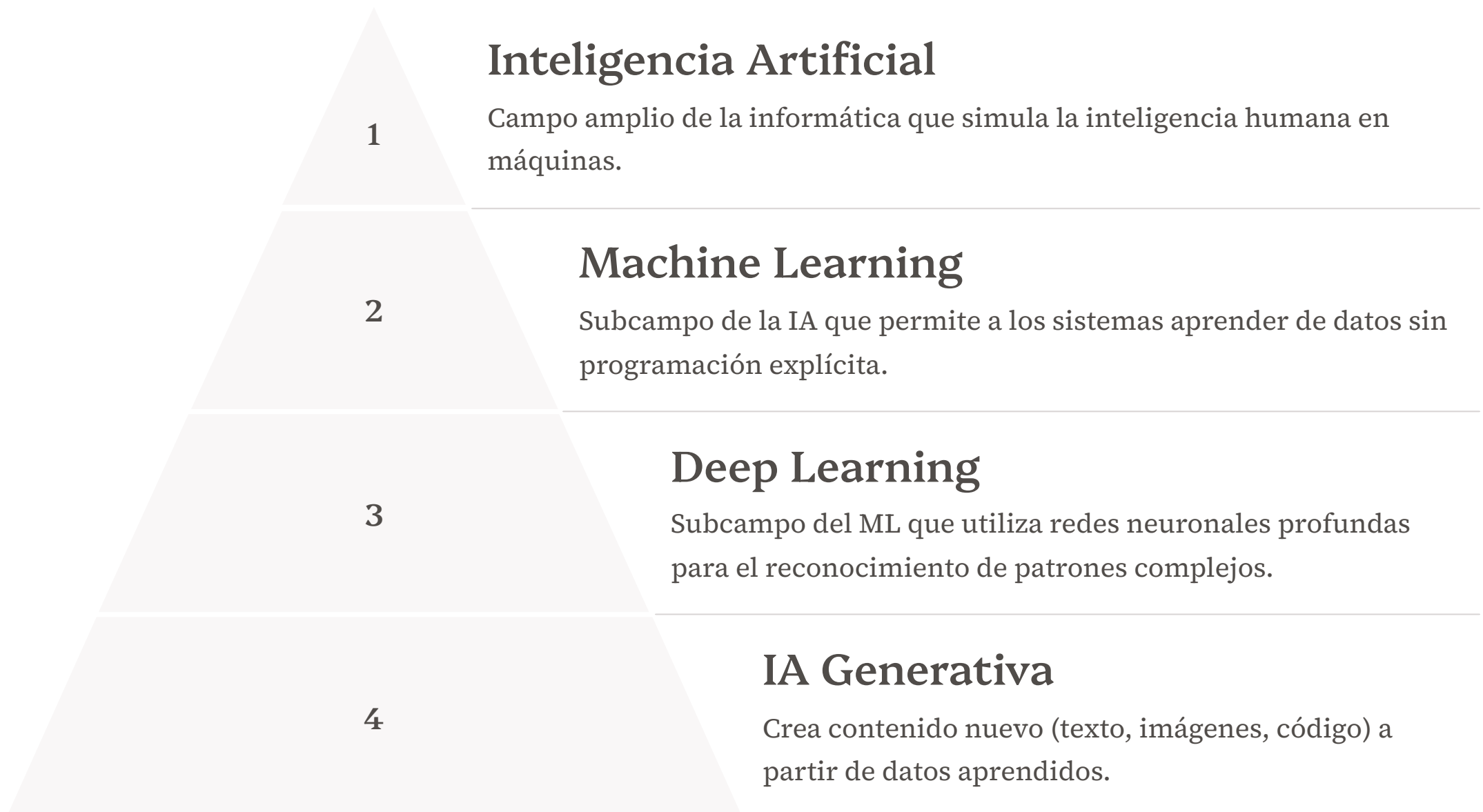
2

Defensas Predictivas

Identificando amenazas nunca antes vistas mediante patrones aprendidos (Zero Days)

Conceptos de IA, ML, DL e IAGen

Para entender la ciberseguridad inteligente, es clave diferenciar sus pilares tecnológicos:



Cada capa se basa en la anterior, representando una progresión desde la automatización básica hasta la creación autónoma de contenido inteligente.

Fundamentos de ML para Ciberseguridad

¿Qué es el Machine Learning?

Es una rama de la IA que permite a los sistemas aprender de los datos sin ser programados explícitamente.



Modelos Clasificadores

Etiquetan datos en categorías predefinidas (ej: "spam" o "no spam"). Utilizan características aprendidas para determinar a qué clase pertenece cada elemento nuevo.



Detección de Anomalías

Identifican patrones inusuales que se desvían del comportamiento normal. Cruciales para detectar ataques zero-day o comportamientos sospechosos no vistos antes.



Entrenamiento

El proceso de "enseñar" a un modelo usando un conjunto de datos. Se necesitan datos de calidad y en cantidad suficiente para crear modelos robustos y precisos.



El Aliado: La IA como tu Perro Guardián

The screenshot shows the Google Gemini web interface. On the left is a sidebar with the 'Gemini' logo and a menu containing 'Gemini', 'Chats', 'Response', 'Semi out', 'Settings', 'Datnor contacts', 'Configurization', and 'Help out'. The main area is titled 'Gemini' and contains a 'Prompt (User input):' section with the text: 'Analiza este texto. ¿Ves señales de riesgo o phishing? [Texto pegado del correo anterior]'. Below this is a 'Response (AI output):' section with a light blue background, containing the text: 'Análisis de Seguridad: ALTO RIESGO. 1. Genera urgencia artificial (amenaza con suspensión de pago). 2. Solicita datos sensibles mediante un enlace externo. 3. El tono es inusualmente agresivo para RRHH. Recomendación: No hagas clic. Contacta a RRHH directamente.'

Ante la duda, usa la IA para validar la información. Copia, pega y pregunta.

Evaluación de Modelos de Seguridad

Un modelo con "99% de precisión" puede ser terrible. Necesitamos las métricas correctas.

Precisión (Precision)

De todas las alertas que generó, ¿cuántas fueron realmente amenazas? Ayuda a evitar los falsos positivos que generan fatiga de alertas.

Exhaustividad (Recall)

De todas las amenazas reales, ¿cuántas logró detectar el modelo? Crucial para evitar que amenazas pasen desapercibidas.

⊗ Falso Positivo

Una alerta sobre una amenaza que no existía. Genera trabajo innecesario y puede llevar a que se ignoren alertas reales.

⚠ Falso Negativo

No detectar una amenaza real. **¡Este es el más peligroso!** Puede permitir que un ataque continúe sin ser detectado.

En ciberseguridad, a menudo preferimos tener algunos falsos positivos a tener un solo falso negativo crítico.

Práctica 1: Reconocimiento y vulnerabilidades en la web

Podemos usar diversas herramientas de reconocimiento para evaluar nuestra propia exposición y encontrar vulnerabilidades, o para investigar a un objetivo.



Google Hacking (Dorks)

Búsquedas avanzadas para encontrar información sensible expuesta públicamente. Muy útil para buscar archivos o directorios específicos.

```
site:"dominio" ext:sql
```



Wayback Machine

Accede a versiones archivadas de sitios web a lo largo del tiempo. Permite investigar cambios históricos, contenido eliminado o configuraciones antiguas que puedan revelar información.

Wayback Machine

[consultants.apple.com/macamerica.php](https://www.archive.org/web/consultants.apple.com/macamerica.php)



Have I Been Pwned

Verifica si tus credenciales o las de tu organización han sido expuestas en alguna brecha de datos. Esencial para comprobar si las contraseñas corporativas están comprometidas.

<https://haveibeenpwned.com>



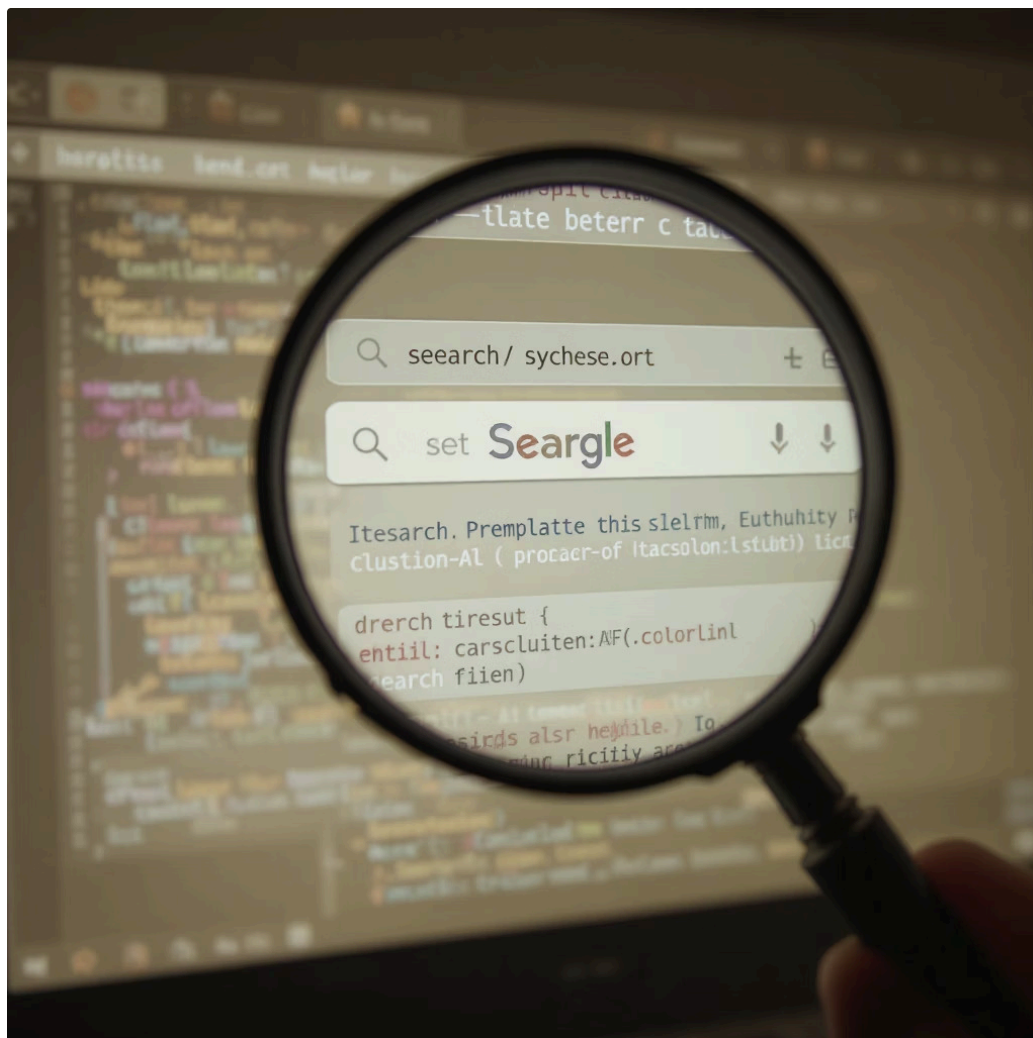
Reverse IP Lookup

Identifica otros dominios que comparten la misma dirección IP de un servidor. Esto puede revelar conexiones o infraestructuras compartidas (por ejemplo, ver qué otros sitios están alojados en los mismos servidores que un sitio de gobierno inclusive).

<https://viewdns.info>

Práctica 2: Google Hacking (Dorks) en Detalle

Las "Google Dorks" son técnicas avanzadas de búsqueda que utilizan operadores específicos de Google para encontrar información sensible expuesta públicamente en la web. Son una herramienta poderosa para el reconocimiento y la evaluación de la superficie de ataque de una organización.



Aquí hay algunos ejemplos comunes y su significado:

Archivos Sensibles

```
ext:txt inurl:"dominio" password
```

Busca archivos de texto (.txt) dentro de dominios que contengan la palabra "password". Esto puede revelar credenciales expuestas.

```
ext:sql inurl:"dominio"
```

Identifica archivos de base de datos (.sql) expuestos en dominios. A menudo, estos contienen volcados de bases de datos con información crítica.

Dispositivos Conectados

```
inurl:view/view.shtml
```

Comúnmente usado para encontrar páginas de acceso a cámaras IP o dispositivos de videovigilancia que están expuestos a internet.

```
inurl:view/index.shtml
```

Similar al anterior, esta dork apunta a otra URL común para interfaces de dispositivos IoT o cámaras web, que podrían estar accesibles sin la debida protección.

Explorando Más Allá: Herramientas Bonus

Además de las técnicas de "dorking" y los servicios mencionados, existen otras herramientas y enfoques que pueden ser increíblemente útiles para el reconocimiento y el análisis de la superficie de ataque.



WebMii

Un motor de búsqueda de personas que agrega información disponible públicamente de diversas fuentes en línea. Útil para investigar la presencia digital de individuos y potenciales vectores de ingeniería social.

<https://webmii.com/>



Instant Username

Permite verificar la disponibilidad de nombres de usuario en cientos de sitios web y redes sociales. Ayuda a identificar la huella digital de una persona o entidad en diferentes plataformas.

<https://instantusername.com/>



Análisis de Metadatos (FOCA)

Herramientas como **FOCA (Fingerprinting Organizations with Collected Archives)** extraen metadatos de documentos (Word, Excel, PDF) y archivos multimedia. Esta información oculta puede revelar nombres de usuarios, rutas de red, versiones de software y otra data sensible.

En entornos corporativos, el análisis de metadatos de sistemas como **SQL Server 2019** puede exponer configuraciones, nombres de bases de datos y usuarios de sistema.



Riesgos de Exposición de Datos (Ej. ChatWatch)

Algunas herramientas, como **ChatWatch** permiten monitorear la actividad de contactos de WhatsApp, exponiendo cuándo estaban en línea o dormidos. Estos ejemplos demuestran la importancia de entender qué datos nuestros y de nuestra organización están públicamente accesibles, incluso a través de servicios aparentemente inofensivos.

<https://chatwatch.net/>

Práctica 3: Detección de Spam y Phishing

<https://bit.ly/4gl3FnQ>



¿Cómo funciona?

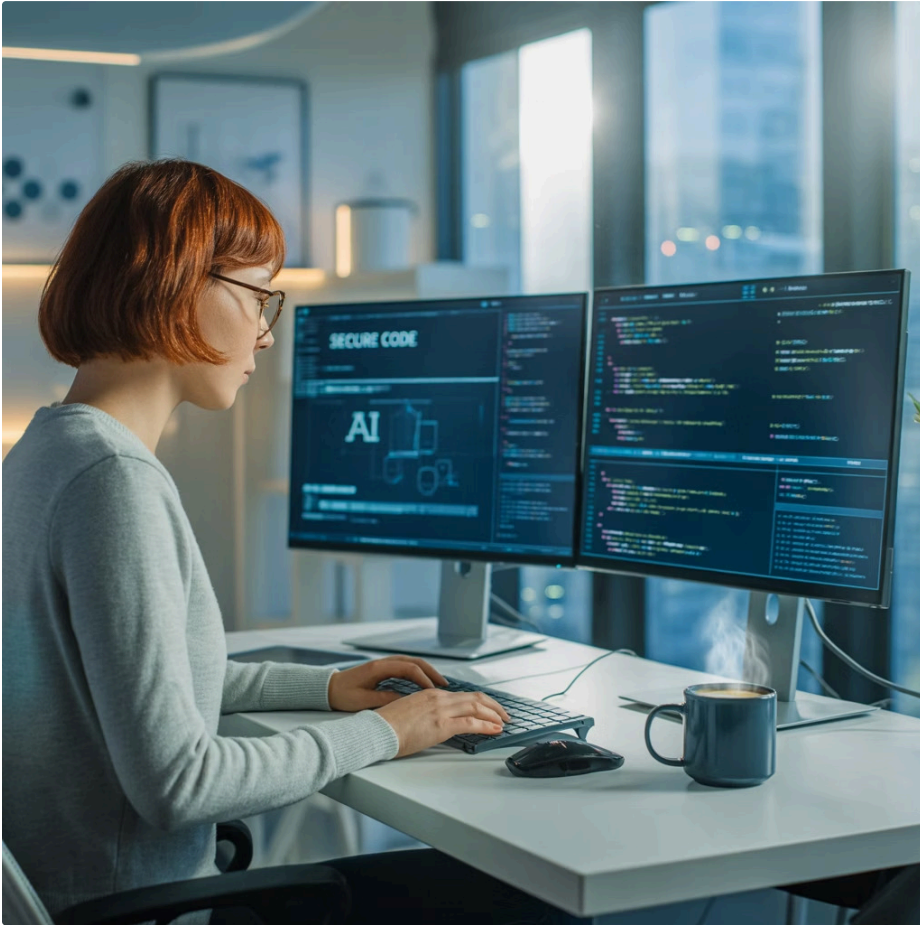
Un modelo de ML analiza miles de correos electrónicos y aprende a distinguir las características de un mensaje malicioso.

Características (Features) que analiza:

- El remitente y la reputación del dominio
- La presencia de palabras clave sospechosas ("urgente", "premio", "verificar cuenta")
- La estructura de las URLs y si usan acortadores
- El formato y la gramática del texto

El modelo asigna una probabilidad de que el correo sea phishing o spam y lo bloquea si supera un umbral determinado.

Práctica 4: Defensas con IA Moderna



Podemos usar herramientas de IA modernas para construir nuestras propias soluciones de seguridad.

Google AI Studio y Gemini API

Potentes modelos de lenguaje generativo accesibles vía API que pueden analizar textos sospechosos y detectar intentos de ingeniería social.

LangChain

Un framework que facilita la conexión de estos modelos con fuentes de datos externas para crear aplicaciones complejas de ciberseguridad.

Con ellos, podemos crear chatbots para analizar correos sospechosos, generar reportes de seguridad o incluso automatizar respuestas a incidentes en tiempo real.

Conclusiones y Cómo Protegerse



La Ingeniería Social es la mayor amenaza

Explota al eslabón más débil: el ser humano. El 80% de los ataques están relacionados con errores humanos.



La IA es un arma de doble filo

Está potenciando tanto los ataques como las defensas. Debemos entender ambas caras de la moneda.



La mejor defensa es el conocimiento

La conciencia y educación sobre estas tácticas son nuestra primera línea de defensa.

Recomendaciones Prácticas:

Sé escéptico

No confíes en comunicaciones no solicitadas, especialmente si generan urgencia o piden acciones inmediatas.

Verifica siempre

Llama a un número conocido para confirmar una solicitud inusual, incluso si parece venir de un superior.

Educa y entrena

Implementa programas regulares de formación en ciberseguridad para toda la organización.

Fortalezca su Defensa: Ciberseguridad para su Empresa

En el dinámico panorama digital actual, la ciberseguridad ya no es solo una cuestión técnica; es una habilidad esencial para cada miembro de su equipo.



Charlas Motivacionales

Sesiones inspiradoras para concientizar a su personal sobre las últimas amenazas y la importancia de la seguridad digital.



Talleres Prácticos

Capacitación interactiva con ejercicios reales para desarrollar habilidades prácticas en la detección y prevención de ciberataques.



Programas Personalizados

Diseñamos contenido a la medida de las necesidades específicas y el nivel de madurez en ciberseguridad de su organización.

Contáctenos para diseñar un programa de capacitación que transforme a sus empleados en su primera línea de defensa.

Preguntas y Agradecimientos



M. en C. Joan David González Franco

correo: joandavid@cicese.edu.mx

teléfono: 5539969440

LinkedIn: <https://www.linkedin.com/in/joandgonzalezf/>



Gracias por su atención.

No dudes en contactar para más información sobre cómo implementar soluciones de ciberseguridad inteligente en tu organización.